



Vulnerability Assessment &
Penetration Testing (VAPT) Report

Ambledown Financial Services (PTY) Ltd

27 June 2022



TABLE OF CONTENTS

1	EXECUTIVE SUMMARY	3
2	SCOPE OF TESTING	3
3	METHODOLOGIES USED	3
3.1	NMAP / ZENMAP.....	3
3.2	NESSUS	3
3.3	GREENBONE ENTERPRISE	3
4	STAY ONE STEP AHEAD OF ATTACKERS	4
4.1	OWASP.....	4
4.2	BRUTE FORCE	5
4.3	APPLICATIONS USED IN BRUTE FORCE INCLUDE:.....	5
5	INFRASTRUCTURE.....	6
5.1	AFRIHOST SERVER – 154.0.171.224	6
5.2	DATA KEEPERS SERVER – 102.67.139.234.....	7
5.3	FIREWALL – HEAD OFFICE PORT FORWARDS – 41.169.103.84	10
5.4	ACTIVE DIRECTORY / VPN SERVER.....	11
5.5	FORTIGATE FIREWALL RULES.	12
5.6	WIRELESS NETWORK.....	13
6	REPORTING CONCLUSION	13
7	AUDITORS	14



1 EXECUTIVE SUMMARY

The purpose of this assessment was to point out security loopholes, business logic errors, and missing best security practices. The tests were carried out assuming the identity of an attacker or a malicious user but, no harm was made to the functionality or working of the application / network. A full scan was also performed on the infrastructure to demonstrate a known attack, i.e. someone on the internal network or same public subnetted infrastructure. The scans and brute force were performed over 11 (eleven) business days, as full and slow comprehensive audits were performed. These types of scans also look at unknown connectivity options, including packet SYN requests.

The overall results will be published below, High-level, Sautech is comfortable and happy with the results. Some recommendations however, is offered and also mentioned throughout this document.

2 SCOPE OF TESTING

Security assessments include testing for security loopholes in the scope defined below. Apart from the following, no other information was provided. Nothing was assumed at the start of the security assessment. The following scope of servers were covered under the security audit:

- Server hosted at Afrihost - 154.0.171.224
- Server hosted at DataKeepers – 102.67.139.234
- Firewall at Head Office and associated Port Forwards – 41.169.103.84
- Active Directory Policies
- FortiGate Firewall Rules
- Wireless Network Security

3 METHODOLOGIES USED

Sautech performed various audit techniques that includes the following:

3.1 Nmap / Zenmap

Nmap, short for Network Mapper, is a free and open source tool used for vulnerability checking, port scanning and, of course, network mapping. Despite being created back in 1997, Nmap remains the gold standard against which all other similar tools either commercial or open source, are judged.

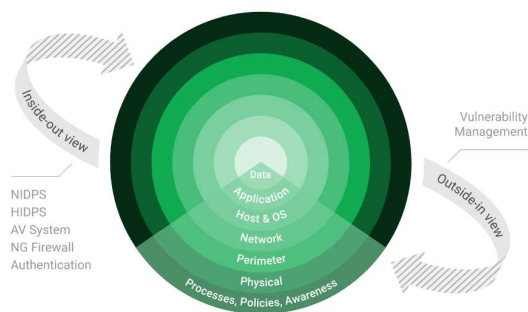
To deploy Nmap, users originally had to have some advanced programming skills, with the introduction of the Zenmap tool for Nmap, which adds a graphical interface that makes launching the program and analysing the returned output it generates much more accessible.

3.2 Nessus

Nessus is a remote security scanning tool, which scans a computer and raises an alert if it discovers any vulnerabilities that malicious hackers could use to gain access to any computer you have connected to a network. It does this by running over 1200 checks on a given computer, testing to see if any of these attacks could be used to break into the computer or otherwise harm it.

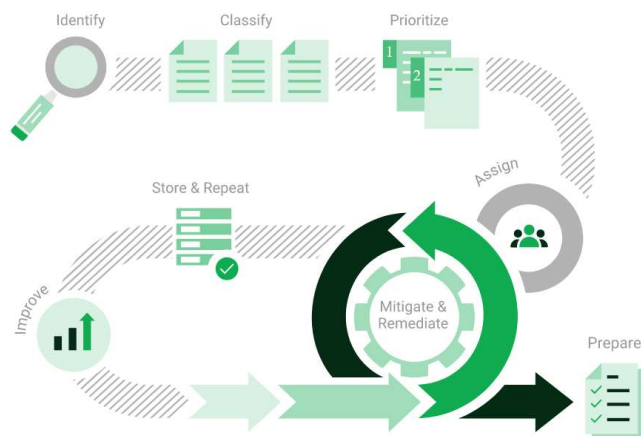
3.3 Greenbone Enterprise

Greenbone is the world's most widely used vulnerability management provider.



4 STAY ONE STEP AHEAD OF ATTACKERS

IT security is a process – Open Source vulnerability management provides the foundation. Once you know where the chinks are in your armor, you can do something about them.



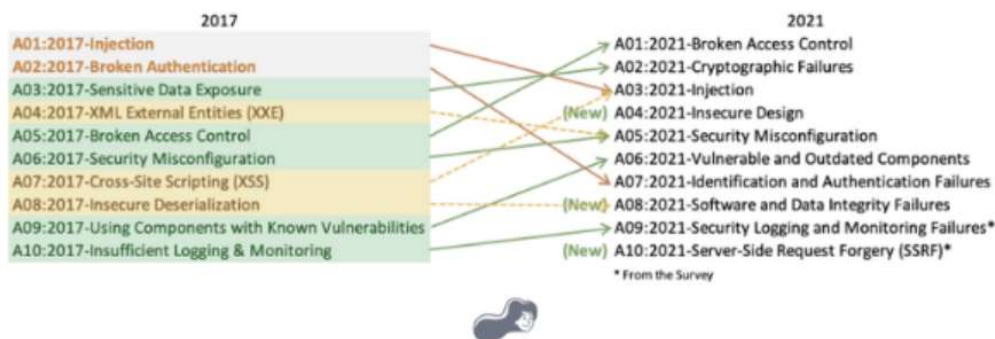
The process – from recognition to remedy and monitoring – represents a continuous cycle. You'll always be one step ahead of attackers.

4.1 OWASP

The Open Web Application Security Project (OWASP) is an online community that produces freely-available articles, methodologies, documentation, tools, and technologies in the field of web application security. The Open Web Application Security Project (OWASP) provides free and open resources. It is led by a non-profit called The OWASP Foundation. The OWASP Top 10 - 2021 is the published result of recent research based on comprehensive data compiled from over 40 partner organizations.



TOP 10:2021 Vulnerabilities



4.2 BRUTE FORCE

- A brute force attack is a hacking method that uses trial and error to crack passwords, login credentials, and encryption keys. It is a simple yet reliable tactic for gaining unauthorized access to individual accounts and organizations' systems and networks. The hacker tries multiple usernames and passwords, often using a computer to test a wide range of combinations, until they find the correct login information.
- The name "brute force" comes from attackers using excessively forceful attempts to gain access to user accounts. Despite being an old cyberattack method, brute force attacks are tried and tested and remain a popular tactic with hackers

4.3 Applications used in Brute Force Include:

Hydra is a parallelized network login cracker built in various operating systems like Kali Linux, Parrot and other major penetration testing environments. Hydra works by using different approaches to perform brute-force attacks in order to guess the right username and password combination. Hydra is commonly used by penetration testers together with a set of programmes like crunch,[2] cupp[3] etc, which are used to generate wordlists. Hydra is then used to test the attacks using the wordlists that these programmes created.

Over 1 Million + Username and password combos are used to Brute force application like RDP, SSH etc.

```
[STATUS] 25.93 tries/min, 20408 tries in 13:07h, 61 to do in 00:03h, 4 active
[STATUS] 25.93 tries/min, 20431 tries in 13:08h, 38 to do in 00:02h, 4 active
[STATUS] 25.93 tries/min, 20455 tries in 13:09h, 14 to do in 00:01h, 4 active
1 of 1 target completed, 0 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2022-06-07 02:59
31
(root@kali)-[/usr/share/wordlists/dirb]
```



5 INFRASTRUCTURE

5.1 Afrihost Server – 154.0.171.224

We have performed three types of scans / attacks on the production server namely:

- Port Mapping (Open / Exposed Services) These were performed from unknown and known locations to test not just the security from the perimeter, but also include local network. Based on the port mapping open access to Public and Private, selected coordinated assessments were performed specific to the open connectivity received.
- Vulnerability Assessments.
- Bruce Force Attacks.

i) Port Mapping

Nmap can be used by hackers **to gain access to uncontrolled ports on a system**. All a hacker would need to do to successfully get into a targeted system would be to run Nmap on that system, look for vulnerabilities, and figure out how to exploit them.

Nmap Scan Report - Scanned at Tue Jun 7 13:29:01 2022

Scan Summary | [ambledowncloud.dedicated.co.za \(154.0.171.224\)](#)

Scan Summary

Nmap 7.92 was initiated at Tue Jun 7 13:29:01 2022 with these arguments:
nmap -sS -sV -T4 -A -v -PE -PP -PSB0,443 -PA3389 -PU40123 -P-g 53 --script 'default or (discovery and safe)' 154.0.171.224
Verbosity: 1; Debug level 0

154.0.171.224 / [ambledowncloud.dedicated.co.za](#)

Ports

The 1000 ports scanned but not shown below are in state: **open|filtered**

The 996 ports scanned but not shown below are in state: **filtered**

Port	State (toggle closed [0] filtered [0])	Service	Reason	Product	Version	Extra info
21	tcp open	ftp	syn-ack	Microsoft ftppd		
110	tcp open	pop3	syn-ack	hMailServer pop3d		
143	tcp open	imap	syn-ack	hMailServer imapd		
3306	tcp open	mysql	syn-ack	MySQL	5.5.5-10.2.6-MariaDB	

Remote Operating System Detection

- Used port: 21/tcp (open)
- OS match: **Microsoft Windows Server 2012 or Windows Server 2012 R2 (89%)**
- OS match: **Microsoft Windows Server 2012 R2 (89%)**
- OS match: **Microsoft Windows Server 2012 (87%)**

As detected above, Windows 2012 is being used on the server. As per the Microsoft support lifecycle, the extended support/update release will end October 2023. It is highly recommended to upgrade to a Later version OS as soon as possible.

Support Dates

Listing	Start Date	Mainstream End Date	Extended End Date
Windows Server 2012 R2	Nov 25, 2013	Oct 9, 2018	Oct 10, 2023

ii) Vulnerability Assessment

Multiple technologies were used to perform a vulnerability assessment, below is the summarised version of the relevant results:

We have attached the below “highlight” in a separate report so that you can click on the “Plugin” link to get the resolution.



154.0.171.224



Vulnerabilities

Total: 38

SEVERITY	CVSS V3.0	PLUGIN	NAME
CRITICAL	9.8	20007	SSL Version 2 and 3 Protocol Detection
HIGH	7.5	42873	SSL Medium Strength Cipher Suites Supported (SWEET32)
MEDIUM	6.8	78479	SSLv3 Padding Oracle On Downgraded Legacy Encryption Vulnerability (POODLE)
MEDIUM	6.5	104743	TLS Version 1.0 Protocol Detection
MEDIUM	6.5	157288	TLS Version 1.1 Protocol Deprecated
MEDIUM	5.9	65821	SSL RC4 Cipher Suites Supported (Bar Mitzvah)
LOW	2.6*	15855	POP3 Cleartext Logins Permitted

iii) Brute Force

Randomised usernames with a word list containing more than 1+ million words and common passwords were brute forced SSH's onto the server using Hydra.

Hydra works by **using different approaches to perform brute-force attacks in order to guess the right username and password combination**. Hydra is commonly used by penetration testers together with a set of programmes like crunch, cupp etc, which are used to generate wordlists.

```
root@kali: /usr/share/wordlists/dirb
C
(root@kali)-[/usr/share/wordlists/dirb]
$ hydra -l mip -P /usr/share/wordlists/dirb/big.txt 41.76.215.242 -t 4 ssh
Hydra v9.2 (c) 2021 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2022-06-06 13:49:36
[DATA] max 4 tasks per 1 server, overall 4 tasks, 20469 login tries (l:1/p:20469), ~5118 tries per task
[DATA] attacking ssh://41.76.215.242:22/
[STATUS] 40.00 tries/min, 40 tries in 00:01h, 20429 to do in 08:31h, 4 active
[STATUS] 28.00 tries/min, 84 tries in 00:03h, 20385 to do in 12:09h, 4 active
[STATUS] 26.29 tries/min, 184 tries in 00:07h, 20285 to do in 12:52h, 4 active
[STATUS] 26.93 tries/min, 404 tries in 00:15h, 20065 to do in 12:25h, 4 active
[STATUS] 26.06 tries/min, 808 tries in 00:31h, 19661 to do in 12:35h, 4 active
[STATUS] 26.04 tries/min, 1224 tries in 00:47h, 19245 to do in 12:19h, 4 active
[STATUS] 26.10 tries/min, 1644 tries in 01:03h, 18825 to do in 12:02h, 4 active
```

5.2 Data Keepers Server – 102.67.139.234

We have performed three types of scans/attacks on the production server namely:



- Port Mapping (Open / Exposed Services) These were performed from unknown and known locations to test not just the security from the perimeter but also include local network.
- Vulnerability assessments
- Bruce Force Attacks

i) Port Mapping

Nmap can be used by hackers **to gain access to uncontrolled ports on a system**. All a hacker would need to do to successfully get into a targeted system would be to run Nmap on that system, look for vulnerabilities, and figure out how to exploit them.

The below screenshot demonstrates the open network port mapping:

Nmap Scan Report - Scanned at Tue Jun 7 08:03:02 2022

Scan Summary | 102.67.139.234

Scan Summary

Nmap 7.92 was initiated at Tue Jun 7 08:03:02 2022 with these arguments:
nmap -SS -SU -TF -A -V -PE -PP -PS80,443 -PA3389 -PU0125 -Pr -g 53 --script "default or (discovery and safe)" 102.67.139.234
Verbosity: 1; Debug level 0

102.67.139.234

Ports

The 1000 ports scanned but not shown below are in state: **open|filtered**
The 996 ports scanned but not shown below are in state: **filtered**

Port	State (toggle closed [0] filtered [0])	Service	Reason	Product	Version	Extra info
3306	tcp open	mysql	syn-ack	MySQL	5.5.5-10.4.8-MariaDB	
3389	tcp open	ms-wbt-server	syn-ack	Microsoft Terminal Services		
8080	tcp open	http	syn-ack	Microsoft IIS httpd	10.0	
9000	tcp open	http	syn-ack	Microsoft IIS httpd	10.0	

Remote Operating System Detection

- Used port: 3306/tcp (open)
- OS match: **AVTech Room Alert 26W environmental monitor** (87%)
- OS match: **Microsoft Windows XP SP3** (85%)

We Recommend closing RDP (3389) or either of the following perform RDP is Accessed

- VPN with Certificate (not username and password combination)
- Configure Local Firewall to only accept RDP connections from known source address
- Install 2FA i.e. Google Authenticator.

ii) Vulnerability Assessment

Multiple technologies were used to perform a vulnerability assessment, below is the summarised version of the relevant results:

We have attached the below "highlight" in a separate report so that you can click on the "Plugin" link to get the resolution.



102.67.139.234



Vulnerabilities

Total: 30

SEVERITY	CVSS V3.0	PLUGIN	NAME
HIGH	7.5	42873	SSL Medium Strength Cipher Suites Supported (SWEET32)
MEDIUM	6.5	51192	SSL Certificate Cannot Be Trusted
MEDIUM	6.5	57582	SSL Self-Signed Certificate
MEDIUM	6.5	104743	TLS Version 1.0 Protocol Detection
MEDIUM	6.5	157288	TLS Version 1.1 Protocol Deprecated
MEDIUM	4.0	58453	Terminal Services Doesn't Use Network Level Authentication (NLA) Only



5.3 Firewall – Head Office Port Forwards – 41.169.103.84

i) Port Mapping

Nmap can be used by hackers **to gain access to uncontrolled ports on a system**. All a hacker would need to do to successfully get into a targeted system would be to run Nmap on that system, look for vulnerabilities, and figure out how to exploit them.

Nmap Scan Report - Scanned at Tue Jun 7 17:08:38 2022

Scan Summary | **41.169.103.84**

Scan Summary

Nmap 7.92 was initiated at Tue Jun 7 17:08:38 2022 with these arguments:
nmap -sS -u -T4 -A -v -PE -PP -PS80,443 -PA3389 -PU40125 -PY -g 53 --script '(default or (discovery and safe))' 41.169.103.84
Verbosity: 1; Debug level 0

41.169.103.84

Ports

The 997 ports scanned but not shown below are in state: **open|filtered**
The 992 ports scanned but not shown below are in state: **filtered**

Port	State (toggle closed [4] filtered [0])	Service	Reason	Product	Version	Extra info
21	tcp open	ftp	syn-ack	FileZilla Ftpd	0.9.34 beta	
22	tcp open	ssh	syn-ack	Bitvise WinSSHD	6.47	FlowSsh 5.39; protocol 2.0
445	tcp open	microsoft-ds	syn-ack	Microsoft Windows Server 2008 R2 - 2012 microsoft-ds		
541	tcp open	reverse-ssl	syn-ack	SSL/TLS ClientHello		
1723	tcp open	pptp	syn-ack	Microsoft		
8008	tcp open	http	syn-ack	Apache httpd	2.4.41	(Ubuntu) mod_wsgi/4.6.8 Python/3.8
500	udp open	isakmp	script-set	Fortinet FortiGate	v5	

Remote Operating System Detection

- Used port: 21/tcp (open)
- Used port: 113/tcp (closed)
- Used port: 520/udp (closed)
- OS match: **Microsoft Windows Server 2008 or 2008 Beta 3 (90%)**
- OS match: **Microsoft Windows 7 SP1 (87%)**
- OS match: **Microsoft Windows Server 2012 (87%)**
- OS match: **Microsoft Windows Server 2012 or Windows Server 2012 R2 (87%)**
- OS match: **Microsoft Windows Server 2012 R2 (87%)**
- OS match: **Linux 3.18 (87%)**
- OS match: **Microsoft Windows Server 2008 R2 or Windows 8 (86%)**
- OS match: **Microsoft Windows Server 2008 R2 SP1 (86%)**
- OS match: **Microsoft Windows Server 2008 (86%)**
- OS match: **Microsoft Windows Server 2008 R2 (86%)**

ii) Vulnerability Assessment

Multiple technologies were used to perform a vulnerability assessment, below is the summarised version of the relevant results:

We have attached the below “highlight” in a separate report so that you can click on the “Plugin” link to get the resolution.



41.169.103.84



Vulnerabilities

Total: 58

SEVERITY	CVSS V3.0	PLUGIN	NAME
CRITICAL	9.8	20007	SSL Version 2 and 3 Protocol Detection
HIGH	7.5	42873	SSL Medium Strength Cipher Suites Supported (SWEET32)
MEDIUM	6.8	78479	SSLv3 Padding Oracle On Downgraded Legacy Encryption Vulnerability (POODLE)
MEDIUM	6.5	104743	TLS Version 1.0 Protocol Detection
MEDIUM	6.5	157288	TLS Version 1.1 Protocol Deprecated
MEDIUM	5.9	65821	SSL RC4 Cipher Suites Supported (Bar Mitzvah)
MEDIUM	5.3	10677	Apache mod_status /server-status Information Disclosure
MEDIUM	5.3	110291	Bitwise SSH Server < 7.41 Multiple Vulnerabilities (remote)
MEDIUM	5.3	57608	SMB Signing not required
LOW	3.7	153953	SSH Weak Key Exchange Algorithms Enabled
LOW	2.6*	70658	SSH Server CBC Mode Ciphers Enabled

5.4 Active Directory / VPN Server

The Active Directory analysis was performed onsite with our team and a couple of items to note below:

1. Password Policies

- Complexity and known passwords we are comfortable with, we will however recommend extending the password length from 8 – 14 characters
- Password lockout option is disabled, we recommend enabling this. This is what happens when there is no lockout policy, within time, the password will be brute forced: (picture below is taken within a 40 second time span)

```
root@kali:~# cat passlist.txt | the-pptp-bruter -u temp1 41.169.103.84
PPTP Connection established.
Hostname '', Vendor 'Microsoft', Firmware: 0
5 passwords tested in 0h 00m 00s (5.00 5.00 c/s)
423 passwords tested in 0h 00m 05s (83.60 84.60 c/s)
854 passwords tested in 0h 00m 10s (86.20 85.40 c/s)
1269 passwords tested in 0h 00m 15s (83.00 84.60 c/s)
1503 passwords tested in 0h 00m 20s (46.80 75.15 c/s)
1786 passwords tested in 0h 00m 25s (56.60 71.44 c/s)
2003 passwords tested in 0h 00m 30s (43.40 66.77 c/s)
2080 passwords tested in 0h 00m 35s (15.40 59.43 c/s)
2178 passwords tested in 0h 00m 40s (19.60 54.45 c/s)
```

- Domain account rename from administrator to something arbitrary “mainuser”
Because of this, we were able to retrieve the password hash with Wireshark



Administrator:500:aad3b435b51404eeaad3b435b51404ee:07c19e98f0ee02e10fce023c82d43c4d:::

- d) Windows Server 2008 is used and there is no more support or updates to this software, upgrade to newer version as a matter of urgency
- e) Local firewall is disabled, enable and only allow services that is needed
- f) No Anti-Virus was detected or installed on the AD Server – Critical
- g) Consider changing the VPN from user/pass based authentication to user/cert-based authentication
- h) We have not gone through internal policies for user creating/deletion etc, but noticed a lot of “test” user accounts connecting via VPN. These are the first accounts hackers use together with administrator/admin guest to brute force accounts.

TIME IT TAKES A HACKER TO BRUTE FORCE YOUR PASSWORD IN 2022					
Number of Characters	Numbers Only	Lowercase Letters	Upper and Lowercase Letters	Numbers, Upper and Lowercase Letters	Numbers, Upper and Lowercase Letters, Symbols
4	Instantly	Instantly	Instantly	Instantly	Instantly
5	Instantly	Instantly	Instantly	Instantly	Instantly
6	Instantly	Instantly	Instantly	Instantly	Instantly
7	Instantly	Instantly	2 secs	7 secs	31 secs
8	Instantly	Instantly	2 mins	7 mins	39 mins
9	Instantly	10 secs	1 hour	7 hours	2 days
10	Instantly	4 mins	3 days	3 weeks	5 months
11	Instantly	2 hours	5 months	3 years	34 years
12	2 secs	2 days	24 years	200 years	3k years
13	19 secs	2 months	1k years	12k years	202k years
14	3 mins	4 years	64k years	750k years	16m years
15	32 mins	100 years	3m years	46m years	1bn years
16	5 hours	3k years	1.73m years	3bn years	92bn years
17	2 days	69k years	9bn years	179bn years	7tn years
18	3 weeks	2m years	467bn years	11tn years	438tn years

 [Learn about our methodology at hivesystems.io/password](https://hivesystems.io/password)

5.5 FortiGate Firewall Rules.

For Security reasons, we will not paste the firewall rules here, this can be obtained manually if need be.

We have only analysed the inbound rules as was the mandate and did not evaluate outbound, IPS or user policies. When we tried to login to the firewall, we were happy to note that entering the wrong password three times. We are also happy to know that the Web UI interface is not accessible via browser externally.

We cannot comment on rules created and why it's needed or not, but we do note there might be some rules that is old/outdated/not needed anymore. Although they pose no direct risk, we would disable/delete what is not needed.

On the rest of the firewall configuration, we are comfortable.



5.6 Wireless Network.

We performed a wireless network scan/attack from Kali Linux.

The SSID should be hidden as its easy identifiable by name to which company it belongs and we could then detect easily what Encryption was used. Based on the encryption we knew the amount of characters that will be maximum and scanned the wireless network password.

Please consider changing the password to more Upper/lower/numeric/Symbolic Combinations. Also, please consider when the SSID is hidden, to install a guest WIFI off the main network, separate Vlan with breakout.

```
[+] Access Point Name: Amb_Office_WiFi
[+] Access Point BSSID: 20:4E:7F:81:74:9E
[+] Encryption: WPA
[+] Handshake File: hs/handshake_AmbOfficeWiFi_20-4E-7F-81-74-9E_2022-06-20T04-53-32.cap
[+] PSK (password): 3ns3rv1c3swifi
[+] saved crack result to cracked.json (2 total)
[+] Finished attacking 1 target(s), exiting
[!] Note: Leaving interface in Monitor Mode!
[!] To disable Monitor Mode when finished: airmon-ng stop wlan0
```

6 REPORTING CONCLUSION

Based on the OWASP reports it is best to attach these separate to the reporting document. These reports can then be shared with the relevant contractors and/or support personnel to implement the changes and updates.

It is our view that from External Testing where the SSH port are not open to public, these vulnerabilities then become academic. However, we still recommend that the changes be implemented. Ambledown Financial Services is behind the managed FortiGate firewall.

The HTTPS updates as these are open to the public, low and medium risk, should be tested and implemented as soon as possible.

From a Hosted Infrastructure point of view, we are happy with the results. We do recommend that SenitnelOne is implemented into the production environment as soon as possible. We also recommend where Operating systems are end of life or close to, they be upgraded.

Six addendum reports are attached to this report and should be read as one document.

With the following test performed:

- Network scanning
- IDS/IPS disabled
- Knows network attack (from Internet to the FW)
- External HTTP and Port exploits
- Vulnerability assessment on CVE
- Penetration testing on login ports i.e.: ssh open

.



7 AUDITORS

These audits were concluded over a period of 15 days.
We hereby confirm that the above information is true and correct:

27th June 2022 – Krugersdorp, South Africa

Riaan van Jaarsveld
Security Expert – CCSA

Lukas Janse van Rensburg
Security Engineer